

CISSP Printable Practice Exam 20 - Domain 4 - Communication and Network Security

Practice Exam 03 - Domain 4

Choose the best answer for each question. For multi-select items, select all required answers.

Question 1 (CISSP3-060)

Scenario: After an acquisition, two companies must exchange a limited set of application flows, but both use the same private IPv4 address ranges. Immediate enterprise-wide renumbering is not feasible.

Which solution BEST enables the required connectivity while limiting security impact?

- A. Bridge the two networks at Layer 2 and permit duplicate addresses to coexist.
- B. Publish all internal services through unrestricted public addresses.
- C. Use controlled address translation at an interconnection zone with explicit flow rules and logging.
- D. Advertise both identical address ranges through the same routing domain without translation.

Question 2 (CISSP3-061)

Scenario: A public information service operates from several geographically separated sites. The network architect wants clients to use one destination address while routing directs each request toward an available nearby site.

Which communication model BEST supports this objective?

- A. Broadcast, because every site must receive every client packet
- B. Anycast, because the same address can be announced from multiple service locations
- C. Multicast, because each client should join the server group before connecting
- D. Unicast with one fixed route, because location diversity does not affect path selection

Question 3 (CISSP3-062)

Scenario: An environmental monitoring system sends frequent sensor updates. A late retransmission has little value because a newer reading will already exist, but the application can tolerate occasional loss and verify sequence numbers itself.

Which transport choice is MOST appropriate?

- A. TCP, because every delayed reading must be retransmitted before newer data can be processed
- B. TCP, because connection establishment eliminates all packet loss on the network
- C. UDP, because it automatically guarantees ordered and acknowledged delivery
- D. UDP, with application-level sequencing and integrity controls suited to the telemetry requirement

Question 4 (CISSP3-063)

Scenario: Users can establish sessions with a remote service and exchange small messages, but larger transfers stall after a new tunnel is introduced. Packet captures show that oversized packets require a smaller path size, while the messages needed to report that condition are being filtered.

What is the BEST corrective action?

- A. Permit the required path-MTU discovery messages and configure tunnel overhead consistently.
- B. Increase application authentication timeouts without changing network policy.

- C. Move the service to a different TCP port while retaining the same packet handling.
- D. Disable routing between the users and the remote service.

Question 5 (CISSP3-064)

Scenario: An organization does not intentionally provide IPv6 service, yet several endpoints can automatically encapsulate IPv6 traffic inside IPv4. Existing monitoring does not inspect the inner traffic.

Which TWO actions BEST reduce the resulting risk? Select 2 of the 5 options below.

- A. Treat the outer IPv4 header as proof that the inner traffic is approved.
- B. Disable unneeded automatic tunneling mechanisms on managed endpoints.
- C. Permit all encapsulated traffic because IPv6 is not formally deployed.
- D. Detect and filter unauthorized tunnel protocols at network boundaries.
- E. Exclude tunneled traffic from security logging to reduce alert volume.

Question 6 (CISSP3-065)

Scenario: A food-processing plant operates legacy controllers that cannot run endpoint security software and communicate with only two management servers. Production availability prevents immediate replacement.

Which design provides the BEST compensating protection?

- A. Place the controllers on the general office network so existing tools can reach them.
- B. Create a dedicated industrial segment with tightly allowlisted flows through monitored enforcement points.
- C. Give each controller direct Internet access for vendor troubleshooting.
- D. Use a shared VLAN with guest devices to reduce the number of network zones.

Question 7 (CISSP3-066)

Scenario: A conference center must offer Internet access to visitors using unmanaged devices. Visitors do not need access to one another or to any internal business system.

Which configuration BEST meets the requirement?

- A. Bridge guest wireless into the employee network and depend on host firewalls.
- B. Give guests the employee wireless credentials but restrict the network name from view.
- C. Use a separate guest segment with client isolation and Internet-only egress controls.
- D. Place visitor devices in the server management VLAN during the event.

Question 8 (CISSP3-067)

Scenario: A bank allows orchestration tools to update software-defined network policy through controller APIs. A scripting error recently created an overly broad route before administrators noticed the change.

What should the security architect recommend as the PRIMARY improvement?

- A. Allow each automation tool unrestricted controller privileges to prevent deployment failures.
- B. Rely on manual review of monthly traffic reports after policy changes occur.
- C. Move the controller API onto the same segment as public application traffic.
- D. Enforce least-privilege API roles, predeployment policy validation, approval controls, and immutable change logs.

Question 9 (CISSP3-068)

Scenario: An education platform uses a content delivery network for static course media. A proposed configuration would also cache personalized grade pages using URLs that do not uniquely identify each authorized session.

Which action BEST protects confidentiality while retaining delivery benefits?

- A. Cache approved public media while bypassing shared caching for personalized responses and enforcing origin authorization.
- B. Cache every response for the longest available duration to reduce origin traffic.
- C. Remove transport protection because cached content is already distributed.
- D. Use identical cache keys for all authenticated users to improve efficiency.

Question 10 (CISSP3-069)

Scenario: A cloud-hosted application has public web, internal service, and database tiers. Workload addresses can change, but the database must accept connections only from the service tier and administrative access must use a controlled path.

Which TWO measures BEST support the design? Select 2 of the 5 options below.

- A. Permit database access from the entire cloud address range to accommodate scaling.
- B. Apply workload-identity or tier-based policy allowing only the required service-to-database flow.
- C. Publish the database listener to the Internet and rely only on its login screen.
- D. Use one shared network segment with unrestricted east-west traffic.
- E. Route administration through a separate authenticated management entry point.

Question 11 (CISSP3-070)

Scenario: A manufacturing enterprise has added firewall rules for years without expiration dates. The rule base now contains broad exceptions, duplicate entries, and specific deny rules that may be overridden by earlier permits.

Which activity would BEST reduce the risk?

- A. Move all deny rules to the end without testing application dependencies.
- B. Convert every rule to a permanent permit to simplify troubleshooting.
- C. Add a second firewall with an identical unreviewed rule set.
- D. Recertify business need, analyze rule order and usage, test changes, and remove obsolete access.

Question 12 (CISSP3-071)

Scenario: A retailer uses redundant Internet links, and inbound and outbound packets from the same session may follow different paths. A stateful intrusion detection sensor sees only one direction and produces incomplete analysis.

Which design change is MOST appropriate?

- A. Disable event correlation so each packet is evaluated without session context.
- B. Monitor only the higher-bandwidth link and infer traffic on the other path.
- C. Aggregate visibility from both paths into an inspection design that can reconstruct complete sessions.
- D. Place the sensor on an unrelated internal segment with lower traffic volume.

Question 13 (CISSP3-072)

Scenario: A health benefits portal uses a load balancer that passes encrypted connections directly to application servers. The security team needs centralized application-layer filtering but must also protect traffic from the load balancer to the server tier.

Which architecture BEST meets both requirements?

- A. Terminate TLS at a controlled inspection tier, apply policy, and establish new protected connections to the application servers.
- B. Send plaintext from Internet clients to the load balancer and encrypt only the internal hop.
- C. Retain end-to-end pass-through while claiming the load balancer inspects decrypted application content.
- D. Copy private server keys to every network device regardless of function.

Question 14 (CISSP3-073)

Scenario: Managed laptops frequently operate from home and public networks without a continuous enterprise tunnel. The organization needs to restrict unsolicited inbound connections regardless of the network to which a laptop is attached.

Which control MOST directly provides this protection?

- A. A perimeter router rule that applies only while the laptop is in the office
- B. A centrally managed host firewall with location-aware policy and protected configuration
- C. A public DNS record listing every laptop address
- D. A larger address pool on each home network

Question 15 (CISSP3-074)

Scenario: A university is redesigning administration of routers, switches, firewalls, and wireless controllers. Management interfaces are currently reachable from user networks, and several devices still accept unprotected administrative protocols.

Which design change would BEST protect the management plane?

- A. Continue using cleartext management protocols but restrict them to normal business hours.
- B. Permit management sessions from user networks after password authentication.
- C. Use a restricted administrative network with protected protocols and individually attributable access.
- D. Use one shared administrator account across all devices to simplify emergency access.

Question 16 (CISSP3-075)

Scenario: A tax advisory firm permits remote access to confidential client systems. Stolen user passwords have been used from unmanaged computers, and the firm wants to verify both the person and the connecting device.

Which solution BEST addresses both weaknesses?

- A. A longer user password entered from any device
- B. A shared departmental account restricted by time of day
- C. A public portal that hides its login page from search engines
- D. Multifactor user authentication combined with managed-device certificates and posture policy

Question 17 (CISSP3-076)

Scenario: A payment application sends transactions to an internal processing service across a shared virtual network. Server-only TLS protects the connection, but any workload that can reach the listener may attempt to submit requests.

Which enhancement BEST strengthens channel-level endpoint authentication?

- A. Move the service to an uncommon port and retain anonymous clients.
- B. Use mutually authenticated TLS with controlled workload credentials and certificate validation.
- C. Disable server certificate checks so clients can connect during certificate changes.
- D. Replace the protected connection with plaintext on the shared network.

Question 18 (CISSP3-077)

Scenario: An emergency coordination center carries voice and bulk data over the same wide-area links. During large file transfers, calls experience delay and loss even though signaling systems remain operational.

What is the MOST appropriate network response?

- A. Classify and prioritize authorized voice traffic, apply admission control, and validate link capacity.
- B. Give all traffic the same forwarding treatment to avoid making trust decisions.
- C. Increase call codec bandwidth without evaluating the constrained links.
- D. Disable voice monitoring so quality alerts do not compete with calls.

Question 19 (CISSP3-078)

Scenario: A securities processor uses two network connections to a clearing partner for resilience. Testing shows that the backup path becomes active during failure but does not pass through the same monitoring and filtering controls as the primary path.

Which TWO actions BEST correct the design? Select 2 of the 5 options below.

- A. Leave the backup path unmonitored because it is used only during outages.
- B. Permit broader access on the backup link to make failover more reliable.
- C. Apply equivalent least-privilege filtering and monitoring to both connection paths.
- D. Remove failover testing so the backup configuration remains stable.
- E. Test failover regularly and verify that security policy remains effective after route changes.

ANSWER KEY AND EXPLANATIONS

Question 1 (CISSP3-060) - Correct: C

A controlled interconnection zone can translate conflicting addresses and enforce only the approved application flows while preserving auditability. Layer 2 bridging and duplicate route advertisements create ambiguity, while broad public exposure exceeds the business requirement and expands risk.

Question 2 (CISSP3-061) - Correct: B

Anycast allows multiple service locations to advertise the same destination so routing can direct a client toward an appropriate instance. Broadcast and multicast are one-to-many delivery models, while one fixed unicast route would not provide the desired location-aware distribution.

Question 3 (CISSP3-062) - Correct: D

UDP avoids transport-level retransmission and ordering delays, while the application can implement the limited sequencing and integrity functions it needs. TCP offers reliable ordered delivery but may delay newer data behind retransmissions. UDP itself does not guarantee delivery or order.

Question 4 (CISSP3-063) - Correct: A

The symptoms indicate a path-MTU discovery failure caused by tunnel overhead and blocked control messages. Allowing the necessary messages and aligning MTU settings addresses the network path. Authentication timeouts and port changes do not alter packet size, while disabling routing removes the required service.

Question 5 (CISSP3-064) - Correct: B, D

Disabling unnecessary endpoint tunnels removes the local capability, while boundary detection and filtering address remaining unauthorized encapsulation. The outer header does not validate inner traffic, and broad permission or reduced logging would make the hidden path easier to misuse.

Question 6 (CISSP3-065) - Correct: B

A dedicated segment with narrowly permitted and monitored communication compensates for weak endpoint capabilities and limits lateral movement. General office, guest, or direct Internet connectivity broadens exposure and does not respect the controllers' limited communication requirement.

Question 7 (CISSP3-066) - Correct: C

A separate guest segment, peer isolation, and Internet-only policy prevent visitor devices from reaching internal resources or one another. Shared employee access collapses the trust boundary, hiding a network name provides little protection, and a management VLAN is especially inappropriate for untrusted devices.

Question 8 (CISSP3-067) - Correct: D

Least-privilege automation, validation, controlled approval, and durable audit records reduce both erroneous and unauthorized policy changes. Broad privileges and public exposure increase impact, while monthly retrospective review cannot prevent a dangerous route from becoming active.

Question 9 (CISSP3-068) - Correct: A

Public static objects can benefit from caching, but personalized records should not enter a shared cache unless identity-aware controls safely separate them. Long retention and shared

cache keys risk cross-user disclosure, and distribution does not remove the need for protected transport and authorization.

Question 10 (CISSP3-069) - Correct: B, E

Tier- or identity-based policy remains effective as workload addresses change, while a separate authenticated management path isolates privileged access. Broad address-range permission, public database exposure, and unrestricted east-west traffic weaken the intended boundaries.

Question 11 (CISSP3-070) - Correct: D

A structured recertification supported by order, dependency, and usage analysis restores least privilege without making blind changes. Reordering rules indiscriminately can cause outages, permanent permits increase exposure, and copying the same policy reproduces its weaknesses.

Question 12 (CISSP3-071) - Correct: C

Stateful analysis requires visibility into both directions, so traffic from redundant paths must be combined or inspected at a point where complete sessions are visible. Ignoring a path or discarding session context reduces detection accuracy, and an unrelated segment cannot supply the missing traffic.

Question 13 (CISSP3-072) - Correct: A

Controlled termination enables application inspection, and re-encryption protects the internal server hop. Plaintext client traffic violates confidentiality, pass-through prevents the stated content inspection, and indiscriminate key distribution creates unnecessary compromise points.

Question 14 (CISSP3-073) - Correct: B

A managed host firewall travels with the endpoint and can enforce inbound policy on office, home, and public networks. An office perimeter rule does not follow the laptop, while DNS publication and larger address pools do not restrict unsolicited connections.

Question 15 (CISSP3-074) - Correct: C

A restricted management path reduces exposure, while protected protocols and individual identities safeguard credentials and preserve accountability. Time-limited cleartext administration still exposes credentials, broad user-network reachability enlarges the attack surface, and shared accounts weaken attribution.

Question 16 (CISSP3-075) - Correct: D

Multifactor authentication reduces reliance on a stolen password, while a device certificate and posture policy establish whether the endpoint is managed and compliant. Longer or shared passwords do not verify the device, and hiding a portal does not provide authentication assurance.

Question 17 (CISSP3-076) - Correct: B

Mutual TLS authenticates both the service and the connecting workload while preserving transport protection. An uncommon port does not establish identity, disabling validation weakens trust, and plaintext removes confidentiality and integrity protection.

Question 18 (CISSP3-077) - Correct: A

Quality-of-service classification, admission control, and capacity validation address delay and loss for authorized real-time sessions without admitting more calls than the link can support. Equal treatment ignores application sensitivity, higher codec demand may worsen

congestion, and disabling monitoring does not improve transport behavior.

Question 19 (CISSP3-078) - Correct: C, E

Both paths must enforce equivalent policy, and recurring failover tests must confirm that route changes preserve monitoring and filtering. A rarely used link can still become an attack path, broader permissions violate least privilege, and avoiding tests leaves the organization unaware of control failures until an outage.